Практическое занятие № 2. Анализ рисков

Вариант А. Сервер интернет-магазина

Шаг 1. Краткое описание системы

Сервер интернет-магазина обеспечивает работу сайта, через который покупатели выбирают и заказывают товары. Его используют покупатели, менеджеры магазина и системные администраторы. На сервере хранятся сведения о товарах, заказах и учётных записях пользователей. Самые важные функции — доступ к каталогу, оформление заказов и сохранение данных. Сервер работает круглосуточно и подключён к интернету. Во время распродаж на него может приходиться большая нагрузка. Любой длительный сбой мешает покупателям оформлять заказы и приводит к потерям магазина.

Шаг 2. Таблица «Идентификация рисков»

ID	Описание риска	Объект уязвимости	Угроза
R-01	Отказ жёсткого диска сервера	Аппаратный	Отказ
R-02	Перегрузка сервера при большом числе посетителей	Аппаратный	Блокирование
R-03	Взлом сайта через уязвимое ПО	Программный	Утечка
R-04	Отключение электропитания	Аппаратный	Отказ
R-05	Ошибка администратора при настройке	Человеческий	Ошибка
R-06	Заражение сервера вредоносной программой	Программный	Потеря целостности
R-07	Потеря соединения с интернетом	Аппаратный	Блокирование
R-08	Случайное удаление базы заказов	Информационный	Потеря целостности
R-09	Сбой обновления сайта	Программный	Сбой
R-10	Кража пароля сотрудника	Человеческий	Утечка

Шаг 3. Таблица «Оценка рисков и меры»

ID	Риск	Вероятность (1–5) и обоснование	Тяжесть (1–5) и обоснование	Уровень	Зона	Мера снижения (тип)	Стратегия	Ожидаемый эффект
R-01	Отказ жёсткого диска сервера	3 — Диски со временем изнашиваются	5 — Возможна потеря заказов и базы данных	15	Высокий	Техническая: RAID и резервные копии	Снижение	При отказе диска данные можно восстановить
R-02	Перегрузка сервера при большом числе посетителей	4 — Во время распродаж нагрузка растёт	4 — Сайт и оформление заказов могут остановиться	16	Критический	Техническая: балансировка нагрузки и запас ресурсов	Снижение	Сайт выдерживает больше запросов
R-03	Взлом сайта через уязвимое ПО	3 — В программном обеспечении бывают уязвимости	5 — Могут быть украдены данные покупателей	15	Высокий	Программная: обновления, WAF и проверка уязвимостей	Снижение	Снижается вероятность взлома

ID	Риск	Вероятность (1–5) и обоснование	Тяжесть (1–5) и обоснование	Уровень	Зона	Мера снижения (тип)	Стратегия	Ожидаемый эффект
R-04	Отключение электропитания	3 — Возможны перебои электроснабжения	4 — Сервер прекратит принимать заказы	12	Высокий	Техническая: ИБП и резервное питание	Снижение	Уменьшается длительность простоя
R-05	Ошибка администратора при настройке	3 — Настройки выполняются вручную	4 — Сайт может работать неверно или остановиться	12	Высокий	Организационная: инструкции и проверка изменений	Снижение	Ошибки выявляются до запуска
R-06	Заражение сервера вредоносной программой	3 — Вредоносный файл может попасть на сервер	5 — Данные и работа сайта могут быть нарушены	15	Высокий	Программная: антивирус, контроль доступа и обновления	Снижение	Меньше вероятность заражения и ущерба
R-07	Потеря соединения с интернетом	3 — У провайдера возможны аварии	4 — Покупатели не смогут открыть магазин	12	Высокий	Техническая: резервный канал другого провайдера	Передача	При аварии связь переключается на резерв
R-08	Случайное удаление базы заказов	2 — Удаление возможно из-за ошибки сотрудника	5 — Можно потерять историю заказов	10	Высокий	Программная: резервное копирование и разграничение прав	Снижение	Возможно восстановление удалённых данных
R-09	Сбой обновления сайта	4 — Новые версии иногда содержат ошибки	3 — Отдельные функции могут стать недоступны	12	Высокий	Организационная: тестовый стенд и план отката	Снижение	Неудачное обновление быстро отменяется
R-10	Кража пароля сотрудника	4 — Сотрудник может попасться на фишинг	5 — Посторонний получит доступ к данным и управлению	20	Критический	Программная: двухфакторная аутентификация и ограничение прав	Снижение	Украденного пароля недостаточно для входа

Шаг 4. Таблица «Остаточный риск»

ID	Риск	Исходный уровень	Внедрённые меры	Новый уровень	Остаточный риск приемлем?
R-10	Кража пароля сотрудника	20	Двухфакторная аутентификация, ограничение прав	2 × 4 = 8	Да, средний
R-02	Перегрузка сервера	16	Балансировка нагрузки, резерв ресурсов	2 × 3 = 6	Да, средний
R-03	Взлом сайта через уязвимое ПО	15	Обновления, WAF, проверка уязвимостей	2 × 4 = 8	Да, средний

Новые уровни рассчитаны по формуле «вероятность × тяжесть». Оценки после мер являются предполагаемыми для учебного примера.

Шаг 5. Вывод

Самыми опасными оказались кража пароля сотрудника, перегрузка сервера и взлом сайта. Эти риски могут остановить работу магазина или привести к утечке данных. Для их снижения предложены двухфакторная аутентификация, резервирование ресурсов и защита сайта. После применения мер уровни трёх выбранных рисков уменьшились до среднего. Такой остаточный риск можно считать приемлемым при постоянном контроле. Дополнительного внимания требуют обновления программ, обучение сотрудников и проверка резервных механизмов.